

ANEXO I
TERMO DE SOLICITAÇÃO DE INFORMAÇÕES E DOCUMENTOS Nº 03

O TCE-RJ, por meio da Coordenadoria Setorial de Auditoria em Políticas de Tecnologia da Informação (CAS-TI), está realizando auditoria para verificar os aspectos das políticas de Governança e Gestão de Tecnologia da Informação como norteadores das contratações de TI no Executivo Estadual no âmbito do Sistema Estadual de Tecnologia da Informação e Comunicação – SETIC, que foi estruturado pelo Decreto Estadual nº 47.278/2020.

O questionário em anexo é um instrumento de coleta de dados para mapear o cenário atual das práticas de governança e gestão de tecnologia da informação adotadas pelas organizações do nível setorial do SETIC e seus Setores de TI (assessorias de informática), assim como suas percepções acerca do Sistema SETIC.

A organização deverá preencher a versão *on-line* deste questionário, conforme instruções a seguir. Com o recebimento do termo, a equipe de auditoria encaminha ao responsável designado o *link* com a versão *on-line* do questionário, assim como seu código de acesso, que é pessoal e intransferível.

Recomenda-se que o servidor responsável pelo preenchimento reúna previamente todas as informações necessárias junto aos diversos setores da organização (Jurídico, Controle Interno, Gestão de Pessoal, Gestão de TI, etc.) antes de iniciar o preenchimento *on-line*.

As evidências documentais que suportam as respostas dadas deverão ser reunidas e mantidas à disposição do TCE-RJ para futura verificação de consistência.

A responsabilidade pelas respostas dadas ao questionário é do dirigente máximo da organização, com base nas respostas providas pelas áreas relacionadas.

O questionário é composto por dois tipos de questões:

1. Questão do tipo “múltiplas escolhas”, sinalizada com uma lista de alternativas não exclusivas iniciadas pela representação gráfica ☐, em que uma ou mais opções podem ser selecionadas (☒). Esse tipo de questão objetiva explicitar melhor o grau de adoção do controle adotado.
2. Questão do tipo “única escolha”, sinalizada com uma lista de alternativas mutuamente exclusivas iniciadas pela representação gráfica O, onde a alternativa escolhida deve ser marcada (☒). Existem questões com duas respostas possíveis, sendo uma

positiva (sim) e outra negativa (não), e com seis respostas possíveis, que representam o nível de adoção da prática abordada:

- i. Não adota;
- ii. Há decisão formal ou plano aprovado para adotá-lo;
- iii. Adota em menor parte;
- iv. Adota parcialmente;
- v. Adota em maior parte ou totalmente;
- vi. Não se aplica.

As definições associadas a cada categoria de resposta são as seguintes:

Nível de adoção da prática	Definição
Não adota	A organização ainda não discutiu a adoção da prática; ou discutiu a adoção da prática, mas ainda não há decisão acerca da sua implementação na organização;
Há decisão formal ou plano aprovado para adotá-lo	A organização decidiu expressamente adotar a prática; ou iniciou a elaboração de um plano de ação que abrange o processo, o cronograma e os responsáveis pela implementação da prática (existem esboços do plano de ação ou parte dele); ou concluiu e aprovou a versão final do plano de ação, mas não iniciou a sua implementação;
Adota em menor parte	Para os casos em que o modelo: está em fase de estudo experimental e/ou de projeto piloto; foi definido, mas não implementado; e/ou foi definido, mas somente 15% (ou menos) dos seus elementos foram implementados;
Adota parcialmente	Para os casos em que o modelo foi definido e mais de 15% a 85% dos seus elementos foram implementados;
Adota em maior parte ou totalmente	Para os casos em que o modelo foi definido e mais de 85% dos seus elementos foram implementados; Para as alternativas de respostas “Adota parcialmente” ou “Adota em maior parte ou totalmente”, foram exigidas evidências de adoção da prática;

Nível de adoção da prática	Definição
Não se aplica	A Organização entende que a prática não se aplica a sua realidade, selecionando três possíveis opções com as seguintes interpretações: <u>Não se aplica porque há lei ou norma externa à organização que impede a implementação desta prática</u> - A organização discutiu acerca da adoção da prática e decidiu não a adotar, tendo em vista a existência de lei ou norma, externa à organização, que restringe ou veda a sua adoção. Nesse caso, para a resposta ser considerada válida, o respondente deveria apontar, em campo adicional apresentado pelo sistema, o motivo e os fundamentos legais que impedem a adoção da prática. Foi alertado que normativos internos e outros normativos que possam ser adaptados pelas instâncias internas de governança para melhor aplicação na organização não deveriam ser utilizados como justificativa para a marcação dessa alternativa; <u>Não se aplica porque há estudo(s) que demonstra(m) que o custo de implementar esta prática é maior que o benefício que seria obtido dessa implementação</u> - A organização discutiu acerca da adoção da prática e decidiu não a adotar, tendo em vista a existência de estudo de viabilidade que concluiu que o custo-benefício de sua adoção é desfavorável para a sociedade e para a organização. Nesse caso, para a resposta ser considerada válida, o respondente deveria indicar, em campo adicional apresentado pelo sistema, trabalhos e documentos que evidenciem a realização do estudo de viabilidade; e <u>Não se aplica por outras razões</u> - A organização discutiu acerca da adoção da prática e decidiu não a adotar, tendo em vista a existência de outras razões que impedem a adoção da prática no contexto da organização. Nesse caso, para a resposta ser considerada válida, o respondente deveria apontar, em campo adicional apresentado pelo sistema, as razões pelas quais considera que a prática não é aplicável no contexto da organização.

RESUMO DAS INSTRUÇÕES

- 1) O TCE-RJ envia e-mail ao ponto focal designado pela Administração com as informações de acesso ao Questionário *on-line* e o correspondente código de acesso, que é peçoal e intransferível.
- 2) O ponto focal coleta todas as informações necessárias para preenchimento do questionário junto às áreas, acessa o Questionário *on-line*, responde com as informações previamente levantadas e o submete.

Em caso de dúvidas no preenchimento ou qualquer informação adicional, favor enviar e-mail para auditoriati@tcerj.tc.br ou entrar em contato com um dos seguintes auditores da CAS-TI, pelo telefone (21) 3231-5293:

- Augusto César Benvenuto de Almeida
- João Paulo de Freitas Ramirez

1000 Sistema Estadual de Tecnologia da Informação e Comunicação - SETIC

De acordo com o Decreto Estadual nº 47.278 de 17 de setembro de 2020, o Sistema Estadual de Tecnologia da Informação e Comunicação - SETIC, configura-se como o conjunto de recursos humanos, tecnológicos e de equipamentos voltados para o estabelecimento e a implementação de políticas para a informação e a comunicação pública, sendo estruturado em dois níveis de atuação: I - Direção Geral, representado pelo PRODERJ; e II – Setorial, representado pelas Assessorias de Informática, ou setores equivalentes, de todos os órgãos da administração direta e indireta do estado do Rio de Janeiro, assim chamadas de NSTIC/RJ.

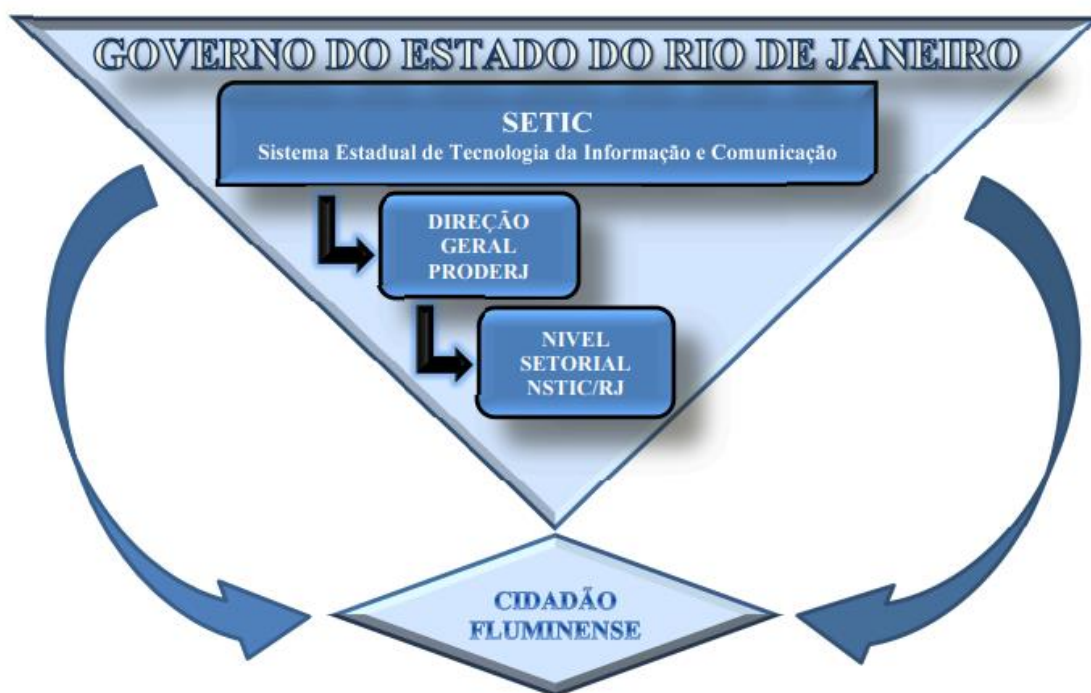


Figura 1- Representação da estrutura do SETIC disposta na Portaria PRODERJ/PRE nº 825/2021

Alinhando-se a essa estrutura apresentada, nessa seção será avaliada a percepção do gestor de TI da organização, pessoa responsável pela assessoria de informática (Setor de TI) da organização, podendo, também, ser denominado como o principal responsável pelo NSTIC/RJ, nos termos do Art. 4º do Anexo C da Portaria PRODERJ/PRE nº 825/2021.

1010 Informações do Setor de TI

1011. A organização possui Setor de TI próprio.

- ☐ Sim
 - ➔ Forneça o nome, e-mail e telefone do Gestor de TI da organização
- ☐ Não
 - ➔ A organização não necessita de TI? Existe um responsável externo à organização? Qual? Está formalizado? Justifique a situação:

? O Setor de TI é a unidade de administração dos recursos de tecnologia da informação, ou seja, responsável pelo planejamento, supervisão, coordenação e controle da tecnologia da informação da organização, além de sua operacionalização.

Enquanto que o Gestor de TI é a pessoa responsável pelo Setor de TI da organização, podendo, também ser denominado como o principal responsável pelo Nível Setorial de Tecnologia da Informação e Comunicação do Estado do Rio de Janeiro – NSTIC/RJ, nos termos do art. 4º do Anexo C da Portaria PRODERJ/PRE nº 825/2021.

1020 Normativos do SETIC

1021. A organização tem conhecimento dos normativos expedidos pelo Diretor Geral do SETIC (PRODERJ).

- ☐ Sim
☐ Não

→ Expresse o motivo:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua resposta:

- ☐ a) Portaria PRODERJ/PRE nº 825/2021, que institui a Política de Governança de Tecnologia da Informação e Comunicação do Estado do Rio de Janeiro – PGTIC/RJ, a Estratégia da Governança de Tecnologia da Informação e Comunicação do Estado do Rio de Janeiro – EGTIC/RJ, e as normas para elaboração do PEDTIC
- ☐ b) Instrução Normativa PRODERJ/PRE nº 01/2021, que regulamenta os procedimentos para contratação e celebração de acordos envolvendo soluções de TIC a serem observados pelos órgãos e entidades do Poder Executivo da Administração Pública Estadual
- ☐ c) Instrução Normativa PRODERJ/PRE nº 02/2022, que regulamenta os procedimentos de segurança da informação a serem observados pelos órgãos e entidades do Poder Executivo da Administração Pública Estadual
- ☐ d) Instrução Normativa PRODERJ/PRE nº 03/2022, que regulamenta os procedimentos e recomendações para o desenvolvimento, migração, sustentação e segurança de sites e portais de internet hospedados no PRODERJ

? Conforme disposto no inciso XVIII, do art. 5º, do Decreto Estadual nº 47.278/2020, foi atribuído ao PRODERJ a competência de, como Diretor Geral do SETIC, disciplinar, por meio de atos, regulamentos e instruções normativas sobre diretrizes técnicas e procedimentais, segurança da informação, contratações de soluções de TIC, adoção de padrões e outros temas correlatos à área de TIC.

1022. A organização atende a Portaria PRODERJ/PRE nº 825/2021 expedida pelo Diretor Geral do SETIC (PRODERJ).

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
- Indique quais as evidências dessa adoção:
- ☐ Não se aplica
- ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
- Indique que leis e/ou normas são essas:
- ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
- Identifique esses estudos:
- ☐ Não se aplica por outras razões.
- Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização constituiu seu Comitê Permanente do PEDTIC

- ☐ b) o Comitê Permanente do PEDTIC é composto, ao menos, pelo principal responsável do NSTIC/RJ como Presidente do Comitê, pelo representante da área de planejamento, pelo representante da área de orçamento, pelo representante da área de administração e patrimônio, pelo representante da área fim da organização e pelo representante da Alta Administração da organização
- ☐ c) a organização elabora seu PEDTIC
- ☐ d) a organização revisa anualmente seu PEDTIC
- ☐ e) a organização possui processo SEI anual e único para registrar a elaboração e revisão de seu PEDTIC, assim como registrar as atas das reuniões do Comitê
- ☐ f) a organização publica em seu próprio portal o PEDTIC elaborado e aprovado
- ☐ g) a organização publicou em Diário Oficial a indicação do principal responsável do NSTIC/RJ e seu suplente

? A Portaria PRODERJ/PRE nº 825/2021 institui a Política de Governança de Tecnologia da Informação e Comunicação do Estado do Rio de Janeiro – PGTIC/RJ, a Estratégia da Governança de Tecnologia da Informação e Comunicação do Estado do Rio de Janeiro – EGTIC/RJ, e as normas para elaboração do PEDTIC.

1023. A organização atende a Instrução Normativa PRODERJ/PRE nº 01/2021 expedida pelo Diretor Geral do SETIC (PRODERJ).

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização encaminha suas solicitações de contratação de solução de TIC à Presidência do PRODERJ por meio do Sistema Eletrônico de Informação - SEI/RJ
- ☐ b) a solicitação de contratação de solução de TIC encaminhada ao PRODERJ possui Documento de Oficialização de Demanda e demais documentos relacionados à pesquisa preliminar de preços
- ☐ c) as contratações de soluções de TIC estão planejadas no respectivo PEDTIC e indicadas no Plano Anual de Contratações
- ☐ d) previamente à adesão a ata de registro de preços gerenciada pelo PRODERJ a organização realiza seu planejamento da contratação e elabora seu Estudo Técnico Preliminar – ETP e Termo de Referência - TR

? A Instrução Normativa PRODERJ/PRE nº 01/2021 regulamenta os procedimentos para contratação e celebração de acordos envolvendo soluções de TIC a serem observados pelos órgãos e entidades do Poder Executivo da Administração Pública Estadual.

1024. A organização atende a Instrução Normativa PRODERJ/PRE nº 02/2021 expedida pelo Diretor Geral do SETIC (PRODERJ).

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:

- ☐ Não se aplica
- ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização mantém procedimentos de segurança da informação, com normas claras, objetivas, revisadas e divulgadas regularmente, com base nas diretrizes estabelecidas na Instrução Normativa PRODERJ/PRE nº 02/2022
- ☐ b) a organização elaborou seus procedimentos de segurança da informação com a participação de representantes de diferentes setores do órgão ou entidade, como, por exemplo, segurança patrimonial, tecnologia da informação e comunicação, recursos humanos e jurídicos
- ☐ c) a organização revisa periodicamente seus procedimentos de segurança da informação
- ☐ d) os procedimentos de segurança da informação foram aprovados pela Alta Administração da organização
- ☐ e) a organização instituiu normas complementares acerca do tema e as publicou em seu portal

? A Instrução Normativa PRODERJ/PRE nº 02/2022, que regulamenta os procedimentos de segurança da informação a serem observados pelos órgãos e entidades do Poder Executivo da Administração Pública Estadual.

1025. A organização desenvolve, sustenta e/ou hospeda seu site ou portal nos ambientes do PRODERJ.

- ☐ Sim
- ☐ Não
- ↳ Expresse o motivo:

Visando explicitar melhor o grau de adoção do controle, marque abaixo os modelos de administração de site ou portal com hospedagem no PRODERJ que são adotados:

- ☐ a) Administração Total do PRODERJ: modelo no qual o PRODERJ desenvolve e sustenta tanto o site ou portal quanto a hospedagem nos ambientes de homologação e produção, conforme disposto no art. 2º, inciso XVI, da Instrução Normativa PRODERJ/PRE nº 03/2022
↳ Indique os sites e/ou portais:
- ☐ b) Administração Parcial do PRODERJ: modelo no qual o PRODERJ desenvolve o site ou portal, gerencia a hospedagem e o ambiente de produção, cabendo ao órgão ou entidade realizar a sustentação por meio do Sistema de Gestão de Conteúdo (Content Management System) ou do ambiente de homologação, conforme disposto no art. 2º, inciso XVI, da Instrução Normativa PRODERJ/PRE nº 03/2022
↳ Indique os sites e/ou portais:
- ☐ c) Administração do Cliente: modelo no qual os ambientes de homologação e produção estão sob total responsabilidade do órgão ou entidade, cabendo ao PRODERJ somente o gerenciamento da hospedagem dos servidores, conforme disposto no art. 2º, inciso XVI, da Instrução Normativa PRODERJ/PRE nº 03/2022
↳ Indique os sites e/ou portais:
- ☐ d) a organização possui sites e/ou portais sob gestão do PRODERJ, mas não está acordado conforme o disposto na Instrução Normativa PRODERJ/PRE nº 03/2022
↳ Indique os sites e/ou portais:

? A Instrução Normativa PRODERJ/PRE nº 03/2022 regulamenta os procedimentos e recomendações para o desenvolvimento, migração, sustentação e segurança de sites e portais de internet hospedados no PRODERJ.

1030 Avaliação do SETIC pelos órgãos setoriais

1031. Nos últimos doze meses, o Gestor de TI recebeu comunicações do Diretor Geral do SETIC (PRODERJ)?

- ☐ Sim
- ☐ Não

? O PRODERJ possui diversos meios para enviar ou receber comunicação aos órgãos pertencentes do nível setorial do SETIC, como, por exemplo, grupos de mensagens na plataforma *Whatsapp*, lista de e-mails, comunicação institucional por ofícios e a Plataforma do AtendeRJ (Central de Atendimento).

1032. Considerando os meios de comunicação disponibilizadas pelo Diretor Geral (PRODERJ), qual a satisfação do Gestor de TI em relação à relevância da comunicação do Diretor Geral com os órgãos setoriais no SETIC?

- ☐ Muito satisfeito
- ☐ Satisfeito
- ☐ Insatisfeito
- ☐ Muito insatisfeito

→ Ajude-nos a entender por que você escolheu a opção acima

? O PRODERJ possui diversos meios para enviar ou receber comunicação aos órgãos pertencentes do nível setorial do SETIC, como, por exemplo, grupos de mensagens na plataforma *Whatsapp*, lista de e-mails, comunicação institucional por ofícios e a Plataforma do AtendeRJ (Central de Atendimento).

1033. Nos últimos doze meses, o Gestor de TI recebeu auxílio e/ou orientação do Diretor Geral do SETIC (PRODERJ)?

- ☐ Sim
- ☐ Não

? Considera-se auxílio as ações pedagógicas, consultivas e orientativas realizadas pelo PRODERJ, como, por exemplo, no âmbito da elaboração e revisão do PEDTIC dos órgãos do nível setorial, ajuda no planejamento das contratações de TIC, oferta de eventos pedagógicos e dialógicos entre Diretor Geral e Setoriais, orientação no cumprimento dos normativos vigentes acerca de tecnologia da informação, entre outras ações.

1034. Qual a satisfação do Gestor de TI em relação ao auxílio e orientação prestados pelo Diretor Geral (PRODERJ) aos órgãos setoriais do SETIC?

- ☐ Muito insatisfeito
- ☐ Insatisfeito
- ☐ Satisfeito
- ☐ Muito satisfeito

→ Ajude-nos a entender por que você escolheu a opção acima

? Considera-se auxílio as ações pedagógicas, consultivas e orientativas realizadas pelo PRODERJ no âmbito da elaboração e revisão do PEDTIC dos órgãos do nível setorial, ajuda no planejamento das contratações de TIC, oferta de eventos pedagógicos e dialógicos entre Diretor Geral e Setoriais, orientação no cumprimento dos normativos vigentes acerca de tecnologia da informação, entre outras ações.

1035. As boas práticas de TIC induzidas pelo Diretor Geral do SETIC (PRODERJ) aos órgãos setoriais ajudaram o Gestor de TI a lidar com seus problemas?

- ☐ Sim, ajudaram bastante
- ☐ Sim, ajudaram de alguma forma
- ☐ Não, realmente não ajudaram
- ☐ Não, aparentemente pioraram as coisas
- ☐ Desconheço as boas práticas de TIC induzidas pelo Diretor Geral (PRODERJ)

→ Ajude-nos a entender por que você escolheu a opção acima

? O Diretor Geral induz a adoção de boas práticas, por exemplo, quando da elaboração de normas técnicas que dispõem de diretrizes, princípios e objetivos a serem perseguidos pelas organizações, da oferta de cursos técnicos, práticos e teóricos por meio do seu programa Academia PRODERJ, da apresentação e fomento de boas práticas em eventos, como o Fórum de TIC ou Café com TIC.

1036. Como o Gestor de TI avalia os atos e normativos de TIC elaborados pelo Diretor Geral do SETIC (PRODERJ) para cumprimento dos órgãos do nível setorial.

	Concordo totalmente	Concordo	Não concordo	Discordo totalmente
Os atos e normativos são de simples compreensão	☐	☐	☐	☐
A matéria de regulamentação dos atos é importante	☐	☐	☐	☐
As obrigações para cumprimento dos atos são exequíveis (viáveis)	☐	☐	☐	☐
Existem temas mais urgentes que ainda não foram regulamentados	☐	☐	☐	☐
Estou preparado para atender aos atos e normativos de TIC elaborados pelo Diretor Geral	☐	☐	☐	☐

➔ Ajude-nos a entender por que você escolheu as opções acima

? O Diretor Geral deve disciplinar por meio de atos, regulamentos e instruções normativas quais as diretrizes técnicas e procedimentais a serem seguidas no âmbito das organizações da Administração Direta e Indireta do Poder Executivo Estadual, sobre segurança da informação, contratações de soluções de TIC, adoção de padrões, além de outros temas correlatos à área de TIC.

1037. Para o Gestor de TI, a atuação do Diretor Geral do SETIC (PRODERJ), como integrador de soluções de TIC, atende as necessidades de TIC da organização.

- ☐ Não, aparentemente pioraram as coisas
- ☐ Não, realmente não ajudaram
- ☐ Sim, ajudaram de alguma forma
- ☐ Sim, ajudaram bastante

➔ Ajude-nos a entender por que você escolheu a opção acima

? O Diretor Geral atua no seu papel de integrador de soluções de TIC quando elabora as atas de registro de preço para participação e aderência dos demais órgãos da Administração Pública Estadual, quando realiza as contratações para os órgãos setoriais ou quando presta diretamente os serviços de TIC.

1038. Considerando os meios de comunicação disponíveis, quando necessário, o atendimento prestado pelo Diretor Geral (PRODERJ) ao Gestor de TI supriu as expectativas.

- ☐ Concordo totalmente
- ☐ Concordo



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO

SECRETARIA GERAL DE CONTROLE EXTERNO

SUBSECRETARIA DE CONTROLE DA RECEITA E POLÍTICAS DE CIDADANIA

COORDENADORIA SETORIAL DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

- ☐ Discordo
- ☐ Discordo totalmente

→ Ajude-nos a entender por que você escolheu a opção acima

? O PRODERJ possui diversos meios para enviar ou receber comunicação aos órgãos pertencentes do nível setorial do SETIC, como, por exemplo, grupos de mensagens na plataforma *Whatsapp*, lista de e-mails, comunicação institucional por ofícios e a Plataforma do AtendeRJ (Central de Atendimento).

QUESTIONÁRIO DE GOVERNANÇA E GESTÃO DE TECNOLOGIA DA INFORMAÇÃO

1100 Governança de tecnologia da informação

1110 Promover a gestão de tecnologia da informação

1111. A alta administração estabeleceu modelo de gestão de tecnologia da informação.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - ↳ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - ↳ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização define as diretrizes para o planejamento de tecnologia da informação
- ☐ b) a organização define as diretrizes para gestão de riscos de tecnologia da informação
- ☐ c) a organização define os papéis e responsabilidades da área de gestão de tecnologia da informação
- ☐ d) a organização designa responsáveis de cada área de negócio para a gestão dos respectivos sistemas informatizados
- ☐ e) a organização dispõe de comitê de tecnologia da informação composto por representantes de áreas relevantes da organização
- ☐ f) o comitê de tecnologia da informação realiza as atividades previstas em ato constitutivo
- ☐ g) a organização define as diretrizes para avaliação do desempenho dos serviços de tecnologia da informação
- ☐ h) a organização estabeleceu objetivos, indicadores e metas para a gestão de tecnologia da informação
- ☐ i) a organização divulga os objetivos, indicadores e metas para a gestão de tecnologia da informação

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Alta Administração; Área de gestão de tecnologia da informação; Área de negócio; Atividades; Comitê de tecnologia da informação; Diretriz; Estabelecer; Gestão; Gestão de riscos; Modelo; Organização; Planejamento de TI; Sistema informatizado ou sistema automatizado; TI (Tecnologia da Informação).

1120. Realizar o monitoramento e avaliação da gestão de tecnologia da informação

1121. A alta administração monitora o desempenho da gestão de tecnologia da informação.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - ↳ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - ↳ Indique quais as evidências dessa adoção:
- ☐ Não se aplica

- ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
↳ Indique que leis e/ou normas são essas:
- ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
↳ Identifique esses estudos:
- ☐ Não se aplica por outras razões.
Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) rotinas de monitoramento do desempenho da gestão de tecnologia da informação estão definidas
- ☐ b) há acompanhamento na execução dos planos vigentes quanto ao alcance das metas estabelecidas
- ☐ c) os indicadores de desempenho da gestão de tecnologia da informação estão implantados (há coleta e análise dos dados necessários à medição de desempenho)
- ☐ d) relatórios de medição de desempenho da gestão de tecnologia da informação estão disponíveis à liderança

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Área de gestão de tecnologia da informação; Gestão do desempenho; Indicador; Indicador de desempenho; Meta; Monitoramento da estratégia; Monitorar o desempenho; TI (Tecnologia da Informação).

1122. A instância superior de governança recebe serviços de auditoria interna que adicionam valor à organização.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
↳ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
↳ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) os serviços de auditoria interna prestados anualmente para a organização cobrem riscos críticos organizacionais
- ☐ b) os serviços de auditoria interna prestados anualmente para a organização cobrem processos de governança organizacional
- ☐ c) os serviços de auditoria interna prestados anualmente para a organização asseguram que as informações constantes das prestações de contas ao controle externo são confiáveis
- ☐ d) os serviços de auditoria interna prestados anualmente para a organização contemplam avaliação da gestão de tecnologia da informação
- ☐ e) os serviços de auditoria interna prestados anualmente para a organização contemplam avaliação da gestão de segurança da informação

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Adicionar/criar valor; Área de gestão de tecnologia da informação; Auditoria interna; Conselho ou Colegiado Superior / instância superior; Informação; Processos de governança; Risco; Risco crítico; Segurança da Informação; Serviços de auditoria; TI (Tecnologia da Informação).

1130. Prestar serviços públicos em meio digital com qualidade

1131. A organização assegura que os serviços acessíveis via internet atendam aos padrões de interoperabilidade, usabilidade e acessibilidade, e que as informações pessoais utilizadas nesses serviços sejam adequadamente protegidas.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização observa as recomendações do Documento de Referência da arquitetura e-PING - Padrões de Interoperabilidade de Governo Eletrônico ou, no caso de organização que não integra o Poder Executivo Federal, observa as melhores práticas equivalentes
- ☐ b) a organização observa as recomendações do guia Padrões Web em Governo Eletrônico: Cartilha de Usabilidade ou, no caso de organização que não integra o Poder Executivo Federal, observa as melhores práticas equivalentes
- ☐ c) a organização garante o acesso da pessoa com deficiência aos serviços e informações que oferece na internet, por meio da adoção de melhores práticas de acessibilidade adotadas internacionalmente (p. ex.: eMAG - Modelo de Acessibilidade em Governo Eletrônico)
- ☐ d) as operações de tratamento de dados pessoais utilizados na prestação de serviços públicos pela organização são realizadas de modo a preservar a intimidade, vida privada, honra e imagem das pessoas às quais se referem
- ☐ e) a organização informa em seu sítio eletrônico as hipóteses em que, no exercício de suas competências, realiza o tratamento de dados pessoais, bem como fornece informações claras e atualizadas sobre a previsão legal, a finalidade, os procedimentos e as práticas de tratamento que utiliza
- ☐ f) informar as melhores práticas adotadas, caso a organização não integre o Poder Executivo Federal e tenha marcado as opções "a" ou "b", bem como se tiver marcado a opção "c":

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Alta Administração; Competências; Informação; Tratamento de dados pessoais.

1132. A organização promove a participação dos usuários com vistas à melhoria da qualidade dos serviços públicos prestados.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.

➔ Identifique esses estudos:

☐ Não se aplica por outras razões.

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

☐ a) a organização promove a participação dos usuários nos esforços de simplificação dos serviços públicos e utiliza as informações assim obtidas como subsídio à definição de metas de simplificação

☐ b) a organização realiza pesquisas de satisfação dos usuários dos serviços públicos prestados em meio digital, propiciando a avaliação desses serviços

☐ c) a organização utiliza os resultados das pesquisas de satisfação como subsídio para promover melhoria na prestação dos serviços

☐ d) a organização comunica amplamente aos usuários os resultados das pesquisas de satisfação realizadas

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Informação; Meta; Serviços públicos prestados em meio digital; Usuário.

1133. A organização definiu metas para a simplificação do atendimento prestado aos usuários dos serviços públicos.

☐ Não adota

☐ Há decisão formal ou plano aprovado para adotá-lo

☐ Adota em menor parte

☐ Adota parcialmente

➔ Indique quais as evidências dessa adoção:

☐ Adota em maior parte ou totalmente

➔ Indique quais as evidências dessa adoção:

☐ Não se aplica

☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.

➔ Indique que leis e/ou normas são essas:

☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.

➔ Identifique esses estudos:

☐ Não se aplica por outras razões.

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

☐ a) a organização definiu metas para a ampliação da oferta de serviços públicos prestados em meio digital

☐ b) a organização definiu metas com vistas à eliminação da exigência de atestados, certidões ou outros documentos comprobatórios que constem em base de dados oficial da administração pública federal, como condição para a prestação de serviços

☐ c) a organização estabeleceu metas no sentido de reduzir a necessidade de atendimento presencial dos usuários em todas as etapas de prestação dos serviços públicos (p. ex.: por meio da automação completa das etapas de: solicitação, acompanhamento de solicitações, execução de procedimentos e comunicação de resultados)

☐ d) a organização definiu metas voltadas à melhoria e ao incremento da atuação integrada e sistêmica com outros órgãos e entidades dos quais dependa ou com os quais interaja intensivamente na prestação dos serviços públicos, tais como metas de compartilhamento de dados e metas de interoperabilidade relacionadas à adoção de procedimentos, ferramentas e plataformas comuns (p. ex. Plataforma de Cidadania Digital)

☐ e) a organização estabeleceu metas com vistas a otimizar o uso de múltiplos canais de atendimento (p. ex.: canal presencial, telefone, canal digital/internet, aplicativos móveis, correio eletrônico etc.), de modo a assegurar que canal adequado esteja disponível para usuários com necessidades especiais e, no caso de serviços críticos e relevantes, que canais alternativos estejam disponíveis, se falhar o canal principal

☐ f) a organização utiliza a gestão de riscos como instrumento para promover a simplificação de procedimentos associados à prestação de serviços públicos, de modo a assegurar que somente sejam utilizados os controles indispensáveis, de acordo com os limites de exposição a riscos institucionalmente definidos, e que sejam eliminados controles desnecessários ou economicamente desvantajosos



TRIBUNAL DE CONTAS DO ESTADO DO RIO DE JANEIRO

SECRETARIA GERAL DE CONTROLE EXTERNO

SUBSECRETARIA DE CONTROLE DA RECEITA E POLÍTICAS DE CIDADANIA

COORDENADORIA SETORIAL DE AUDITORIA EM POLÍTICAS DE TECNOLOGIA DA INFORMAÇÃO

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Controle; Gestão de riscos; Meta; Serviços públicos prestados em meio digital; Usuário.

2100. Gestão de tecnologia da informação

2110. Realizar planejamento de tecnologia da informação

2111. A organização executa processo de planejamento de tecnologia da informação.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) as áreas demandantes de soluções de TI participam do processo de planejamento de tecnologia da informação
- ☐ b) o processo de planejamento de TI integra-se e harmoniza-se com o processo de planejamento institucional
- ☐ c) a organização estabeleceu critérios para orientar a seleção e a priorização das iniciativas de TI (projetos e ações) e os mantém atualizados
- ☐ d) análises de benefícios, de custos e de riscos subsidiam as decisões relacionadas à seleção e à priorização das iniciativas de TI (projetos e ações)
- ☐ e) o processo de planejamento de TI está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)
- ☐ f) a organização avalia periodicamente o desempenho e a conformidade do processo de planejamento de TI e promove eventuais ajustes necessários

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Planejamento de Tecnologia da Informação; Plano de Tecnologia da Informação; Projeto; Risco; TI (Tecnologia da Informação).

2112. A organização possui plano de tecnologia da informação vigente.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) o plano de tecnologia da informação (plano de TI) é aprovado pelo dirigente máximo da organização ou por dirigente ou colegiado que integra a alta administração
- ☐ b) o plano de TI é publicado na internet, para fácil acesso de partes interessadas e da sociedade
- Informar a localização (URL) do Plano de TI
- ☐ c) o plano de TI fundamenta a proposta orçamentária da área de TI e o plano de contratações
- ☐ d) as iniciativas de TI (projetos e ações) constantes do plano de TI alinham-se aos objetivos e iniciativas definidos no plano estratégico e demais planos institucionais, assim como, quando aplicável, às estratégias e objetivos estabelecidos por instâncias de governança superiores (p. ex. Estratégia de Governança Digital - EGD, Estratégia Nacional de Tecnologia da Informação e Comunicação do Poder Judiciário - ENTIC-JUD)
- ☐ e) a seleção de iniciativas de TI (projetos e ações) para compor o plano de TI considera estimativas fundamentadas em dados históricos ou em estudos técnicos sobre a capacidade e a disponibilidade dos recursos de TI da organização (financeiros, humanos, materiais, equipamentos etc.)
- ☐ f) ao elaborar o Plano de TI, a organização avalia iniciativas estratégicas que têm por objetivo ampliar ou melhorar o uso de TI como instrumento de transformação do negócio em benefício da sociedade (transformação digital), especialmente quanto aos riscos de adoção, adoção tardia ou não adoção de tais iniciativas
- ☐ g) é feito acompanhamento concomitante à execução do plano de TI, com vistas a assegurar sua observância e possibilitar a realização de ajustes que se fizerem necessário

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Alta Administração; Conselho ou Colegiado Superior / instância superior; Dirigente máximo; Partes interessadas; Planejamento de Tecnologia da Informação; Plano de Tecnologia da Informação; Projeto; TI (Tecnologia da Informação); Transformação Digital.

2113. A organização recebeu orientação do e/ou interagiu com o Diretor Geral do SETIC (PRODERJ) durante o processo de elaboração do PEDTIC vigente.

- ☐ Não
- Explique as razões dessa adoção:
- ☐ Sim
- Indique quais as evidências dessa adoção:
- ☐ Não se aplica
- ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
- Indique que leis e/ou normas são essas:
- ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
- Identifique esses estudos:
- ☐ Não se aplica por outras razões.
- Explique que razões são essas:

Visando explicitar melhor o grau de adoção, marque abaixo uma ou mais opções:

- ☐ a) a organização recebeu informativo ou comunicação do Diretor Geral do SETIC (PRODERJ) acerca da necessidade de elaboração do PEDTIC
- ☐ b) a organização recebeu auxílio do Diretor Geral do SETIC (PRODERJ) guiando a elaboração do seu PEDTIC
- ☐ c) a organização interagiu com o Diretor Geral do SETIC (PRODERJ) por meio do seu Assessor de Relacionamento com Cliente
- ☐ d) a organização interagiu com o Diretor Geral do SETIC (PRODERJ) por meio de grupos em aplicativos de mensagens (WhatsApp, Telegram etc)
- ☐ e) a organização interagiu com o Diretor Geral do SETIC (PRODERJ) por meio do Atende.RJ
- ☐ f) a organização interagiu com o Diretor Geral do SETIC (PRODERJ) por meio de e-mail ou grupo de e-mail

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: SETIC, PEDTIC.

2120. Gerir serviços de tecnologia da informação

2121. A organização executa processo de gestão do catálogo de serviços.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte

- ☐ Adota parcialmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↪ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↪ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) o catálogo contém as metas definidas para cada serviço (p. ex. prazos de entrega, horários de serviço e de suporte, bem como pontos de contato para solicitação do serviço, envio de sugestões, esclarecimento de dúvidas e reporte de incidentes)
- ☐ b) o catálogo está atualizado e as informações que nele constam são compatíveis com os Acordos de Níveis de Serviço (ANS) estabelecidos pela área de tecnologia da informação e as áreas de negócio da organização
- ☐ c) o catálogo é de fácil acesso e está amplamente disponível a seus usuários e às equipes de suporte

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Catálogo de serviços de TI; Organização; Processo de trabalho; Serviço de TI.

2122. A organização executa processo de gestão de mudanças.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↪ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↪ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização estabeleceu critérios para orientar a aprovação de mudanças, inclusive quanto ao tratamento de casos de exceção (mudanças emergenciais)
- ☐ b) mudanças são previamente comunicadas a todas as partes que possam ser afetadas
- ☐ c) identificam-se os serviços e ativos de TI que possam ser afetados pela mudança, de modo a avaliar impactos em níveis de serviços acordados
- ☐ d) a realização de cada mudança é precedida de planejamento e testes
- ☐ e) mudanças executadas são rastreáveis e monitoradas, com vistas à avaliação de sua efetividade e para permitir ações corretivas, no caso de ocorrência de efeitos não identificados nas fases de planejamento e testes
- ☐ f) lições aprendidas com as mudanças são compartilhadas, com vistas ao aprimoramento do processo (ex: Wiki)
- ☐ g) o processo de gestão de mudanças está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)
- ☐ h) a organização avalia periodicamente o desempenho e a conformidade do processo de gestão de mudanças e promove eventuais ajustes necessários

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Acordo de Nível de Serviço (ANS); Efetividade; Gestão de serviços de tecnologia da informação; Processo de gestão de mudanças.

2123. A organização executa processo de gestão de configuração e ativos (de serviços de tecnologia da informação).

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização mantém uma base de dados consolidada com as configurações dos serviços e ativos de TI e o relacionamento entre eles
- ☐ b) a base de dados de configurações permite à organização conhecer o histórico da situação dos serviços e ativos de TI e do relacionamento entre eles ao longo do tempo
- ☐ c) a base de dados de configurações é mantida atualizada
- ☐ d) a base de dados de configurações é utilizada como insumo para o planejamento e o acompanhamento das mudanças
- ☐ e) o processo de gestão de configuração e ativos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)
- ☐ f) a organização avalia periodicamente o desempenho e a conformidade do processo de gestão de configuração e ativos e promove eventuais ajustes necessários

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Gestão de serviços de tecnologia da informação; Processo de gerenciamento de configuração e ativos; Serviço de TI; TI (Tecnologia da Informação).

2124. A organização executa processo de gestão de incidentes de serviços de tecnologia da informação.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização definiu regras para a priorização e o escalamento de incidentes
- ☐ b) a resolução de incidentes considera os níveis de serviços especificados em acordos com as áreas clientes
- ☐ c) bases de conhecimento sobre erros conhecidos e problemas são utilizadas como insumos na resolução de incidentes

☐ d) o processo de gestão de incidentes está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)

☐ e) a organização avalia periodicamente o desempenho e a conformidade do processo de gestão de incidentes de serviços de tecnologia da informação e promove eventuais ajustes necessários

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Gestão de serviços de tecnologia da informação; Serviço de TI; TI (Tecnologia da Informação).

2130. Gerir nível de serviço de tecnologia da informação

2131. A área de gestão de tecnologia da informação acorda os níveis de serviço com as demais áreas de negócio internas à organização (Acordo de Nível de Serviço - ANS).

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) os ANS estabelecem metas de nível de serviço acordadas com representantes das áreas de negócio clientes
- ☐ b) os ANS são submetidos a revisões regulares, para assegurar que estejam atualizados e sejam efetivos
- ☐ c) os ANS estabelecidos na organização são formalizados
- ☐ d) a área de gestão de tecnologia da informação monitora continuamente o alcance dos níveis de serviço que foram definidos com as áreas de negócio clientes
- ☐ e) a área de gestão de tecnologia da informação comunica às áreas de negócio o resultado do monitoramento do alcance dos níveis de serviço
- ☐ f) a organização comunica aos usuários o resultado do monitoramento do alcance dos níveis de serviço

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Acordo de Nível de Serviço (ANS); Área de gestão de tecnologia da informação; Área de negócio; Organização.

2140. Gerir riscos de tecnologia da informação

2141. A organização executa processo de gestão dos riscos de tecnologia da informação relativos a processos de negócio.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:

☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.

➤ Identifique esses estudos:

☐ Não se aplica por outras razões.

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

☐ a) a organização identifica e avalia os riscos de tecnologia da informação dos processos organizacionais críticos para o negócio

☐ b) a organização trata os riscos de tecnologia da informação dos processos organizacionais críticos para o negócio, com base em um plano de tratamento de risco

☐ c) a organização atribuiu a responsabilidade por coordenar a gestão de riscos de tecnologia da informação

☐ d) o processo de gestão dos riscos de tecnologia da informação está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)

☐ e) a organização avalia periodicamente o desempenho e a conformidade do processo de gestão de riscos de tecnologia da informação e promove eventuais ajustes necessários

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Avaliação de riscos; Estabelecer; Gestão de riscos; Gestão do desempenho; Identificação de riscos; Risco de Tecnologia da Informação; TI (Tecnologia da Informação); Tratamento de risco.

2142. A organização executa processo de gestão da continuidade dos serviços de tecnologia da informação.

☐ Não adota

☐ Há decisão formal ou plano aprovado para adotá-lo

☐ Adota em menor parte

☐ Adota parcialmente

➤ Indique quais as evidências dessa adoção:

☐ Adota em maior parte ou totalmente

➤ Indique quais as evidências dessa adoção:

☐ Não se aplica

☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.

➤ Indique que leis e/ou normas são essas:

☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.

➤ Identifique esses estudos:

☐ Não se aplica por outras razões.

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

☐ a) a organização elabora um plano de continuidade de serviços de TI

☐ b) as ações e os prazos definidos no plano de continuidade de serviços de TI fundamentam-se em análises de impacto no negócio realizadas sobre os processos organizacionais críticos

☐ c) o plano de continuidade de serviços de TI é testado e revisado periodicamente

☐ d) o processo de gestão de continuidade de serviços de TI integra o processo institucional de gestão de continuidade do negócio

☐ e) o processo de gestão de continuidade de serviços de TI está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)

☐ f) a organização avalia periodicamente o desempenho e a conformidade do processo de gestão de continuidade de serviços de TI e promove eventuais ajustes necessários

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Análise de impacto no negócio; Gestão de continuidade do negócio; Gestão do desempenho; Plano de continuidade do negócio; Serviço de TI.

2143. O processo de gestão de riscos da organização está implantado.

☐ Não adota

☐ Há decisão formal ou plano aprovado para adotá-lo

- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) objetivos e elementos (processos, produtos, atividades, ativos) críticos da organização estão identificados
- ☐ b) há lista integrada de riscos, incluindo causas, fontes, efeitos
- ☐ c) os riscos constantes da lista integrada foram analisados e avaliados
- ☐ d) o tratamento dos riscos está documentado
- ☐ e) os responsáveis pelo tratamento dos riscos participam do processo de escolha das respostas aos riscos
- ☐ f) os riscos críticos identificados são informados aos membros das instâncias superiores de governança

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: **Análise de riscos; Atividades; Conselho ou Colegiado Superior / instância superior; Fonte de risco; Identificação de riscos; Processo de gestão de riscos; Resposta a risco; Risco; Tratamento de risco.**

2144. Os riscos considerados críticos para a organização são geridos.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) os riscos críticos estão identificados
- ☐ b) os riscos críticos estão analisados e avaliados
- ☐ c) o tratamento dos riscos críticos está documentado
- ☐ d) há monitoramento periódico dos riscos críticos identificados

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: **Análise de riscos; Avaliação de riscos; Identificação de riscos; Risco; Risco crítico; Tratamento de risco.**

2145. A organização executa processo de gestão de continuidade do negócio.

- ☐ Não adota

- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) há política institucional de gestão de continuidade do negócio (PGCN) aprovada pela alta administração
- ☐ b) o processo de gestão de continuidade do negócio está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)
- ☐ c) há plano de continuidade do negócio (PCN) aprovado pela alta administração
- ☐ d) as ações e os prazos definidos no PCN fundamentam-se em análises de impacto no negócio (Business Impact Analysis – BIA) realizadas sobre os processos organizacionais críticos
- ☐ e) o PCN é testado e revisado periodicamente

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Alta Administração; Análise de impacto no negócio; Gestão de continuidade do negócio; Plano de continuidade do negócio; Política; Política de gestão de continuidade do negócio; Risco.

2146. A estrutura da gestão de riscos está definida.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) há política institucional de gestão de riscos aprovada pelo conselho ou colegiado superior ou pela alta administração
- ☐ b) foram definidas as instâncias responsáveis pelo sistema de gestão de riscos e respectivas competências (p. ex. alta administração, gestores operacionais, gestores de riscos, instância de supervisão da gestão de riscos, instância colegiada de assessoramento, outras funções de segunda linha, auditoria interna)
- ☐ c) foram definidas as diretrizes da integração do processo de gestão de riscos aos processos organizacionais
- ☐ d) foram definidos os critérios de análise e avaliação de riscos (orientações para determinação de níveis de risco, classificação e priorização dos riscos, e ainda para seleção das medidas de tratamento)
- ☐ e) foram definidos os fluxos de comunicação para compartilhar informações e decisões acerca de gestão de riscos
- ☐ f) o processo de gestão de riscos está formalizado
- ☐ g) limites para exposição ao risco estão definidos

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Alta Administração; Análise de riscos; Auditoria interna; Avaliação de riscos; Competências; Conselho ou Colegiado Superior; Critérios de análise e avaliação de riscos; Diretriz; Estrutura da gestão de riscos; Gestão de riscos; Limites de exposição ao risco; Política de gestão de riscos; Processo de gestão de riscos; Risco; Tratamento de risco.

2147. Atividades típicas de segunda linha estão estabelecidas.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↪ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↪ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) foram definidas e atribuídas atividades típicas de segunda linha: facilitação, apoio e monitoramento das atividades de gestão de riscos
- ☐ b) foi definido fluxo de comunicação sobre riscos e controles entre os agentes que executam atividades de segunda linha, os gerentes de áreas (primeira linha), a auditoria interna (terceira linha), e a alta administração
- ☐ c) as atividades da segunda linha incluem o monitoramento da integridade e precisão dos reportes de gestão de riscos
- ☐ d) as atividades da segunda linha incluem o fornecimento de metodologias, ferramentas e orientações em geral para que os gestores (primeira linha) identifiquem e avaliem riscos
- ☐ e) as atividades da segunda linha incluem o suporte aos gestores (primeira linha) na implementação e monitoramento contínuo dos controles internos destinados a mitigar os riscos identificados
- ☐ f) as atividades da segunda linha incluem o apoio às atividades de auditoria interna (terceira linha), no acompanhamento e auxílio da interlocução com as áreas auditadas
- ☐ g) as atividades da segunda linha incluem alertar a gerência operacional (primeira linha) para questões emergentes e para as mudanças no cenário regulatório e de riscos

? Considere segunda linha como a segunda linha de defesa, conforme preceitua o novo modelo das três linhas do Instituto dos Auditores Internos do Brasil (IIA Brasil) de 2020.

Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Alta Administração; Análise de riscos; Auditoria interna; Avaliação de riscos; Competências; Conselho ou Colegiado.

2150. Definir políticas de responsabilidades para a gestão da segurança da informação

2151. A organização dispõe de uma política de segurança da informação.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.

→ Indique que leis e/ou normas são essas:

☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.

→ Identifique esses estudos:

☐ Não se aplica por outras razões.

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

☐ a) a política declara o comprometimento da alta administração e estabelece princípios, diretrizes, objetivos, estruturas e responsabilidades relativos à segurança da informação

☐ b) a política (ou norma interna complementar) contempla diretrizes sobre gestão de riscos de segurança da informação

☐ c) a política abrange diretrizes para conscientização, treinamento e educação em segurança da informação

☐ d) a política é amplamente comunicada a empregados, servidores, colaboradores e partes externas relevantes

☐ e) a política é mantida atualizada, por meio de revisões periódicas

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Alta Administração; Colaboradores; Diretriz; Gestão de riscos; Informação; Política; Política de segurança da informação; Risco de Segurança da Informação; Segurança da Informação.

2152. A organização dispõe de comitê de segurança da informação.

☐ Não adota

☐ Há decisão formal ou plano aprovado para adotá-lo

☐ Adota em menor parte

☐ Adota parcialmente

→ Indique quais as evidências dessa adoção:

☐ Adota em maior parte ou totalmente

→ Indique quais as evidências dessa adoção:

☐ Não se aplica

☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.

→ Indique que leis e/ou normas são essas:

☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.

→ Identifique esses estudos:

☐ Não se aplica por outras razões.

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

☐ a) o comitê de segurança da informação realiza as atividades previstas em seu ato constitutivo

☐ b) o comitê formula diretrizes para a segurança da informação

☐ c) o comitê propõe a elaboração e a revisão de normas e de procedimentos inerentes à segurança da informação

☐ d) o comitê é composto por representantes de áreas relevantes da organização

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Comitê de segurança da informação; Diretriz; Informação; Segurança da Informação.

2153. A organização possui um gestor institucional de segurança da informação.

☐ Não adota

☐ Há decisão formal ou plano aprovado para adotá-lo

☐ Adota em menor parte

☐ Adota parcialmente

→ Indique quais as evidências dessa adoção:

☐ Adota em maior parte ou totalmente

→ Indique quais as evidências dessa adoção:

☐ Não se aplica

☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.

→ Indique que leis e/ou normas são essas:

☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.

➔ Identifique esses estudos:

☐ Não se aplica por outras razões.

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) o gestor institucional de segurança da informação foi designado formalmente pela alta administração
- ☐ b) o gestor institucional de segurança da informação reporta-se diretamente à alta administração
- ☐ c) o gestor institucional de segurança da informação coordena o processo de gestão de riscos de segurança da informação em âmbito institucional
- ☐ d) o gestor institucional de segurança da informação coordena ações de segurança da informação em âmbito institucional
- ☐ e) o gestor institucional de segurança da informação fomenta e coordena ações periódicas de conscientização e de treinamento em segurança da informação para todas as partes interessadas, incluindo autoridades, servidores e colaboradores
- ☐ f) o gestor institucional de segurança da informação detém as prerrogativas e os recursos necessários para o desempenho de todas as suas competências
- ☐ g) o gestor institucional de segurança da informação foi designado dentre os servidores públicos civis ou militares ocupantes de cargos efetivos, lotados na organização e com formação ou capacitação técnica compatível às suas atribuições

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Alta Administração; Competências; Gestão de riscos; Gestor institucional de segurança da informação; Informação; Partes interessadas; Risco de Segurança da Informação; Segurança da Informação.

2154. A organização possui um responsável pelo tratamento e resposta a incidentes.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ➔ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
- ➔ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
- ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
- ➔ Indique que leis e/ou normas são essas:
- ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
- ➔ Identifique esses estudos:
- ☐ Não se aplica por outras razões.
- Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) o responsável pelo tratamento e resposta a incidentes foi designado formalmente pela alta administração
- ☐ b) o responsável pelo tratamento e resposta a incidentes monitora os recursos de TIC, detecta e realiza as análises dos incidentes de segurança da informação
- ☐ c) o responsável pelo tratamento e resposta a incidentes identifica as vulnerabilidades de segurança da informação da organização
- ☐ d) o responsável pelo tratamento e resposta a incidentes recebe e propõe respostas a notificações relacionadas a incidentes de segurança da informação
- ☐ e) o responsável pelo tratamento e resposta a incidentes coordena e executa atividades de tratamento e resposta a eventos de segurança da informação
- ☐ f) o responsável pelo tratamento e resposta a incidentes foi designado dentre os servidores públicos civis ou militares ocupantes de cargos efetivos, lotados na organização e com formação ou capacitação técnica compatível às suas atribuições

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Alta Administração; Competências; Gestão de riscos; Responsável pelo tratamento e resposta a incidentes; Informação; Partes interessadas; Risco de Segurança da Informação; Segurança da Informação.

2160. Estabelecer processos e atividades para a gestão da segurança da informação

2161. A organização executa processo de gestão de riscos de segurança da informação.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização identifica e avalia riscos de segurança da informação
- ☐ b) a organização trata riscos de segurança da informação com base em um plano de tratamento de riscos
- ☐ c) a organização possui um gestor formalmente responsável por coordenar a gestão de riscos de segurança da informação
- ☐ d) o processo de gestão de riscos de segurança da informação está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)
- ☐ e) a organização avalia periodicamente o desempenho e a conformidade do processo de gestão de riscos de segurança da informação e promove eventuais ajustes necessários

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Avaliação de riscos; Gestão de riscos; Gestão do desempenho; Gestor; Identificação de riscos; Informação; Risco de Segurança da Informação; Segurança da Informação; Serviço de TI; Tratamento de risco.

2162. A organização executa processo de controle de acesso à informação e aos ativos associados à informação.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização implementa controles de acesso físicos e lógicos à informação e aos ativos associados à informação que são por ela gerenciados ou custodiados, com vistas a proteger adequadamente a confidencialidade das informações não públicas e a integridade e a disponibilidade das informações consideradas críticas para o negócio
- ☐ b) os controles de acesso implementados na organização aplicam o princípio “necessidade de conhecer”, o qual prescreve que deve haver necessidade legítima que justifique o acesso à informação por pessoa, sistema ou entidade, bem como o princípio “privilegio mínimo”, o qual estabelece que o perfil de acesso concedido deve incluir tão somente os poderes necessários para o atendimento das legítimas necessidades
- ☐ c) há controles de acesso lógicos na organização que utilizam autenticação com certificado digital ICP-Brasil, a fim de prover identificação inequívoca de pessoas físicas e jurídicas e comprovação de autoria em transações digitais
- ☐ d) a organização analisa criticamente, a intervalos regulares, os direitos de acesso lógicos e físicos existentes, com vistas à remoção de direitos que deixaram de ser necessários e para assegurar que privilégios indevidos não foram obtidos
- ☐ e) a organização instituiu uma Política de Controle de Acesso (PCA), a qual estabelece princípios, objetivos, diretrizes, principais atividades e responsabilidades relativos ao processo de controle de acesso
- ☐ f) a organização avalia periodicamente o desempenho e a conformidade do processo de controle de acesso e promove eventuais ajustes necessários

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Ativos associados à informação; Certificado digital; Controle; Diretriz; Gestão do desempenho; Informação; Política; Serviço de TI.

2163. A organização executa processo de gestão de ativos associados à informação.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização mantém um inventário dos ativos associados à informação
- ☐ b) a organização definiu responsabilidades pelos ativos associados à informação
- ☐ c) o inventário identifica as informações críticas que os ativos armazenam, processam ou transmitem
- ☐ d) o processo de gestão de ativos associados à informação subsidia a implantação de controles e ações com vistas a assegurar a adequada proteção dos ativos e das informações que armazenam, processam ou transmitem
- ☐ e) o processo de gestão de ativos associados à informação subsidia a implantação de ações mitigatórias aplicáveis no caso de ocorrência de evento catastrófico que inviabilize a utilização de ativos
- ☐ f) o processo de gestão de ativos associados à informação está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)
- ☐ g) a organização avalia periodicamente o desempenho e a conformidade do processo de gestão de ativos associados à informação e promove eventuais ajustes necessários

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Ativos associados à informação; Gestão do desempenho; Informação; Processo de gestão de ativos.

2164. A organização executa processo para classificação e tratamento de informações.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo

- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - ↳ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - ↳ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) informações pessoais são identificadas e rotuladas, com vistas a viabilizar adequado tratamento e proteção
- ☐ b) a organização adota procedimentos para tratamento e proteção das informações identificadas na forma do item “a” em conformidade com os requisitos legais e de negócio
- ☐ c) informações sigilosas em razão de sua imprescindibilidade à segurança da sociedade ou do Estado são identificadas e rotuladas, com vistas a viabilizar adequado tratamento e proteção
- ☐ d) a organização adota procedimentos para tratamento e proteção das informações identificadas na forma do item “c” em conformidade com os requisitos legais e de negócio
- ☐ e) informações sigilosas em função de outras hipóteses legais de sigilo ou segredo são identificadas e rotuladas, com vistas a viabilizar adequado tratamento e proteção
- ☐ f) a organização adota procedimentos para tratamento e proteção das informações identificadas na forma do item “e” em conformidade com os requisitos legais e de negócio
- ☐ g) informações críticas para a organização em razão de necessidades do negócio (p. ex. requisitos associados à integridade, disponibilidade, autenticidade ou a outros atributos da informação) são identificadas e rotuladas, com vistas a viabilizar adequado tratamento e proteção
- ☐ h) a organização adota procedimentos para tratamento e proteção das informações identificadas na forma do item “g” em conformidade com os requisitos legais e de negócio
- ☐ i) o processo de classificação e tratamento de informações está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)
- ☐ j) a organização avalia periodicamente o desempenho e a conformidade do processo de classificação e tratamento de informações e promove eventuais ajustes necessários

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Gestão do desempenho; Informação; Processo para classificação e tratamento de informações.

2165. A organização executa processo de gestão de incidentes de segurança da informação.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - ↳ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - ↳ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização definiu e comunica amplamente o ponto de contato a ser notificado no caso de ocorrência de incidente de segurança da informação, bem como os canais de comunicação apropriados
- ☐ b) a organização definiu procedimentos e responsabilidades quanto ao tratamento das notificações de incidentes de segurança da informação, adoção de ações emergenciais e diretrizes para escalamento e comunicação interna e externa
- ☐ c) a organização definiu procedimentos e responsabilidades quanto à análise de incidentes de segurança da informação, identificação de causas raízes e planejamento e implementação de ações corretivas
- ☐ d) a organização instituiu equipe de tratamento e resposta a incidentes em redes computacionais (ETIR) ou estrutura equivalente
- ☐ e) o processo de gestão de incidentes de segurança da informação está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)
- ☐ f) a organização avalia periodicamente o desempenho e a conformidade do processo de gestão de incidentes de segurança da informação e promove eventuais ajustes necessários

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Gestão do desempenho; Informação; Processo de gestão de incidentes; Segurança da Informação.

2166. A organização executa atividades de gestão da segurança dos recursos de processamento da informação, inclusive dos recursos de computação em nuvem.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↪ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↪ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização gerencia (inventaria e controla) os dispositivos conectados em sua rede
- ☐ b) a organização gerencia (inventaria e controla) os softwares instalados nos dispositivos conectados em sua rede
- ☐ c) a organização gerencia vulnerabilidades técnicas em seus ativos de software, de hardware e de rede críticos para o negócio
- ☐ d) a organização implementa configurações seguras em seus ativos de software, de hardware e de rede críticos para o negócio
- ☐ e) a organização mantém, monitora e analisa logs de auditoria dos ativos de software, de hardware e de rede críticos para o negócio
- ☐ f) a organização aplica controles compensatórios para o uso de privilégios administrativos em seus ativos de software, de hardware e de rede críticos para o negócio
- ☐ g) a organização implementa defesas contra malware (ex: vírus) e outras ameaças cibernéticas (ex: phishing)
- ☐ h) a organização limita e controla o uso de portas, protocolos e serviços de rede nas conexões de sua rede interna com a internet e outras redes externas
- ☐ i) a organização implementa defesa de perímetro das conexões de sua rede interna com a internet e outras redes externas
- ☐ j) a organização implementa cópias regulares de segurança (backup) das informações em meio digital, conforme as melhores práticas e as necessidades de negócio, incluindo a realização periódica de testes de recuperação das informações
- ☐ k) a organização executa regularmente testes de segurança em seu ambiente de TI (detecção de vulnerabilidades e testes de penetração)

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Informação; Segurança dos recursos de processamento da informação.

2167. A organização realiza periodicamente ações de treinamento e/ou capacitação em segurança da informação.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização realiza ações de capacitação voltadas para segurança da informação
- ☐ b) a organização participa de ações de capacitação voltadas para segurança da informação
- ☐ c) a organização realiza ações de conscientização em segurança de TIC
- ☐ d) a organização possui programa permanente de conscientização em segurança da informação

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Informação; Plano de capacitação (Plano de Treinamento); Segurança da Informação.

2170. Executar processo de software

2171. A organização executa um processo de software.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização possui pessoal próprio capacitado para gerir o processo de software

- ☐ b) a organização avalia as soluções existentes no mercado antes de decidir pelo desenvolvimento de software (análise do tipo “construir ou adquirir”)
- ☐ c) na etapa de planejamento das contratações de soluções de software, a organização realiza estudos para identificar e mitigar o risco de dependência tecnológica, com vistas a viabilizar a substituição de fabricante/fornecedor quando tecnicamente viável e economicamente vantajoso
- ☐ d) a organização utiliza prioritariamente arquiteturas de software que promovem o desacoplamento de soluções, sistemas e componentes, inclusive nos casos de software adquirido e desenvolvimento realizado mediante contratação, com vistas a facilitar a realização de manutenções e otimizar custos
- ☐ e) o processo de software utilizado pela organização promove a participação de representante da área de negócio como integrante da equipe de desenvolvimento ou aquisição de software, desde sua concepção até a aceitação final
- ☐ f) o processo de software da organização promove a identificação precoce de requisitos de segurança da informação e a gestão permanente desses requisitos durante todo o ciclo de vida do software
- ☐ g) o processo de software da organização promove a identificação precoce de requisitos de interoperabilidade e a gestão permanente desses requisitos durante todo o ciclo de vida do software
- ☐ h) o processo de software da organização promove a identificação precoce de requisitos de acessibilidade e de usabilidade, bem como a gestão permanente desses requisitos durante todo o ciclo de vida do software
- ☐ i) a organização assegura os seus direitos autorais, de propriedade e de uso relativamente ao software que desenvolve por meio de contratação
- ☐ j) organização avalia, por meio de mensurações, indicadores e metas, a qualidade do software desenvolvido ou adquirido
- ☐ k) o processo de software está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)
- ☐ l) a organização avalia periodicamente o desempenho e a conformidade do processo de software e promove eventuais ajustes necessários

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Área de negócio; Gestão do desempenho; Identificação de riscos; Indicador; Meta; Mitigar risco; Processo de software; Segurança da Informação.

2180. Gerir projetos de tecnologia da informação

2181. A organização executa processo de gestão de projetos de tecnologia da informação.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↪ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↪ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização possui base de dados consolidada (portfólio) de projetos de tecnologia da informação
- ☐ b) escopo, custos, uso de recursos e cumprimento de prazos são gerenciados em cada projeto
- ☐ c) é realizada a gestão de riscos de cada um dos projetos de alta materialidade ou alta relevância
- ☐ d) o processo de gestão de projetos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades)
- ☐ e) a organização avalia periodicamente o desempenho e a conformidade do processo de gestão de projetos de tecnologia da informação e promove eventuais ajustes necessários

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Gestão de riscos; Gestão do desempenho; Portfólio de projetos de tecnologia da informação; Projeto; Risco; TI (Tecnologia da Informação).

2200. Gestão de Pessoas

2210. Definir adequadamente, em termos qualitativos e quantitativos, a demanda por colaboradores e gestores

2211. Os perfis profissionais desejados para cada ocupação ou grupo de ocupações de gestão estão definidos e documentados.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↪ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↪ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) as responsabilidades e atribuições dos gestores da área finalística estão definidas, documentadas e publicadas
- ☐ b) as responsabilidades e atribuições dos gestores da área finalística são revisadas periodicamente e publicadas
- ☐ c) as responsabilidades e atribuições dos gestores da área administrativa estão definidas, documentadas e publicadas
- ☐ d) as responsabilidades e atribuições dos gestores da área administrativa são revisadas periodicamente e publicadas
- ☐ e) relacionou-se no perfil profissional, além de requerimentos de ordem legal, um conjunto de competências que os ocupantes dos cargos de gestão devem possuir
- ☐ f) a aderência entre os perfis profissionais definidos e as necessidades organizacionais é revisada periodicamente
- ☐ g) a organização utiliza mecanismos de transparência ativa para disponibilizar às partes interessadas internas e externas os perfis profissionais definidos para as ocupações de gestão

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Gestor; Ocupação; Partes interessadas; Perfil profissional; Perfil profissional desejado; Transparência; Transparência ativa; Transparência passiva.

2212. Os perfis profissionais desejados para cada ocupação ou grupo de ocupações de colaboradores da organização estão definidos e documentados.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↪ Indique que leis e/ou normas são essas:

☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.

➔ Identifique esses estudos:

☐ Não se aplica por outras razões.

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

☐ a) as responsabilidades e atribuições das ocupações, ou grupo de ocupações, da área finalística estão definidas, documentadas e publicadas

☐ b) as responsabilidades e atribuições das ocupações, ou grupo de ocupações, da área finalística são revisadas periodicamente e publicadas

☐ c) as responsabilidades e atribuições das ocupações ou grupo de ocupações da área administrativa estão definidas, documentadas e publicadas

☐ d) as responsabilidades e atribuições das ocupações ou grupo de ocupações da área administrativa são revisadas periodicamente e publicadas

☐ e) relacionou-se nos perfis profissionais, além de requerimentos de ordem legal, um conjunto de competências que o ocupante do cargo deve possuir

☐ f) a organização utiliza mecanismos de transparência ativa para disponibilizar às partes interessadas internas e externas os perfis profissionais definidos

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Área finalística; Colaboradores; Competências; Ocupação; Partes interessadas; Perfil profissional; Perfil profissional desejado; Transparência; Transparência ativa; Transparência passiva.

2213. Há definição do quantitativo necessário de pessoal por unidade organizacional ou por processo de trabalho.

☐ Não adota

☐ Há decisão formal ou plano aprovado para adotá-lo

☐ Adota em menor parte

☐ Adota parcialmente

➔ Indique quais as evidências dessa adoção:

☐ Adota em maior parte ou totalmente

➔ Indique quais as evidências dessa adoção:

☐ Não se aplica

☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.

➔ Indique que leis e/ou normas são essas:

☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.

➔ Identifique esses estudos:

☐ Não se aplica por outras razões.

Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

☐ a) há política de orientação para o dimensionamento da força de trabalho

☐ b) definiu-se o quantitativo necessário por unidade organizacional, ou processo de trabalho, com base em critério(s) ou procedimento(s) técnico(s)

☐ c) definiu-se, de maneira documentada, um quantitativo necessário de pessoal por unidade organizacional, ou processo de trabalho, da área finalística

☐ d) definiu-se, de maneira documentada, um quantitativo necessário de pessoal por unidade organizacional, ou processo de trabalho, da área administrativa

☐ e) há revisão periódica do quantitativo de pessoal necessário por unidade organizacional ou processo de trabalho

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Área finalística; Planejamento da força de trabalho; Política; Procedimento técnico; Quantitativo necessário; Unidade organizacional.

2220. Assegurar o adequado provimento das vagas existentes.

2221. A escolha dos gestores ocorre segundo perfis profissionais previamente definidos e documentados.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) avalia-se, previamente à nomeação/designação, se o gestor possui impedimentos legais decorrentes de sanções administrativas, cíveis, eleitorais ou penais, incluindo envolvimento em atos de corrupção
- ☐ b) os gestores da área de finalística são selecionados com base em perfil profissional, previamente, definido e documentado, e compatível com o cargo ou função para o qual tenha sido indicado
- ☐ c) os gestores da área administrativa são selecionados consoante perfil profissional, previamente, definido e documentado, e compatível com o cargo ou função para o qual tenha sido indicado
- ☐ d) são utilizadas ferramentas estruturadas para auxiliar a seleção dos ocupantes dos cargos/funções comissionados de gestão
- ☐ e) são utilizados mecanismos de transparência ativa para disponibilizar às partes interessadas externas e internas o currículo dos ocupantes dos cargos/funções de gestão

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Partes interessadas; Perfil profissional; Perfil profissional desejado; Transparência; Transparência ativa; Transparência passiva.

2230. Desenvolver as competências dos colaboradores e gestores de TI

2231. As lacunas de competências dos colaboradores e gestores da organização são identificadas e documentadas.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) as lacunas de competências pessoais (transversais, comuns a todos os colaboradores) da organização são identificadas e documentadas
- ☐ b) as lacunas de competências de liderança e gestão necessárias para a atuação dos gestores da organização são identificadas e documentadas
- ☐ c) as lacunas de competências técnicas da área finalística necessárias para a atuação dos colaboradores da organização são identificadas e documentadas
- ☐ d) as lacunas de competências técnicas da área administrativa necessárias para a atuação dos colaboradores da organização são identificadas e documentadas

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Área finalística; Colaboradores; Competências; Gestão; Gestor; Lacuna de competência ou de perfil profissional.

2232. As lacunas de competências dos colaboradores e gestores da organização são tratadas.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ↳ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
- ↳ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
- ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
- ↳ Indique que leis e/ou normas são essas:
- ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
- ↳ Identifique esses estudos:
- ☐ Não se aplica por outras razões.
- Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização elabora plano de capacitação (plano de treinamento) visando o tratamento das lacunas de competência identificadas
- ☐ b) a organização incentiva seus colaboradores e gestores a participar das ações de capacitação existentes
- ☐ c) a organização monitora a participação dos colaboradores e gestores nas ações de capacitação existentes
- ☐ d) a organização analisa periódica e criticamente o plano de capacitação (plano de treinamento) existente

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Função de Capacitação; Plano de treinamento; Colaboradores; Competências; Gestão; Gestor; Lacuna de competência ou de perfil profissional.

2233. A organização utiliza as ações de capacitação ofertadas pelo programa Academia PRODERJ.

- ☐ Não
- ↳ Explique as razões dessa escolha:
- ☐ Sim
- ☐ Não se aplica
- ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
- ↳ Indique que leis e/ou normas são essas:
- ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
- ↳ Identifique esses estudos:
- ☐ Não se aplica por outras razões.
- Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização participa de cursos de desenvolvimento de competências em governança de TI

- ☐ b) a organização participa de cursos de desenvolvimento de competências em gestão de TI
- ☐ c) a organização participa de cursos de desenvolvimento de competências em gestão de projetos
- ☐ d) a organização participa de cursos de desenvolvimento de competências em segurança da informação
- ☐ e) a organização participa de cursos de desenvolvimento de competências em contratação de bens e serviços de TI
- ☐ f) a organização participa em outros cursos de desenvolvimento de competências:

→ Informar quais cursos de desenvolvimento de competências

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Função de Capacitação; Plano de treinamento; Colaboradores; Competências; Gestão; Gestor; Lacuna de competência ou de perfil profissional.

2240. Gerir o desempenho dos gestores.

2241. A organização realiza formalmente a avaliação de desempenho individual, com atribuição de nota ou conceito, tendo como critério de avaliação o alcance das metas previstas no plano da unidade.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) há normativo que trata da avaliação de desempenho dos colaboradores e gestores
- ☐ b) a avaliação abrange o desempenho de todos os gestores da área finalística
- ☐ c) a avaliação abrange o desempenho de todos os gestores da área administrativa
- ☐ d) a avaliação abrange o desempenho de todos os colaboradores da área finalística
- ☐ e) a avaliação abrange o desempenho de todos os colaboradores da área administrativa

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Área finalística; Avaliação de desempenho; Colaboradores; Gestor.

2250. Estrutura do corpo técnico

2251. A organização possui em sua estrutura cargos específicos para tecnologia da informação.

- ☐ Sim
 - Indique quais as evidências dessa adoção:
- ☐ Não

2252. A organização possui plano de cargos formalizado contendo cargos específicos de TI.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica

- ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
↳ Indique que leis e/ou normas são essas:
- ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
↳ Identifique esses estudos:
- ☐ Não se aplica por outras razões.
Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) o plano de cargos vigente permite progressão funcional dos colaboradores
- ☐ b) o plano de cargos vigente estimula a capacitação dos colaboradores
- ☐ c) o plano de cargos vigente prevê parcela remuneratória vinculada ao desempenho do colaborador

2300. Gestão de Contratações de Tecnologia da Informação

2310. Gerir riscos em contratações

2311. As equipes de planejamento das contratações analisam os riscos que possam comprometer a efetividade das etapas de Planejamento da Contratação, Seleção do Fornecedor e Gestão Contratual ou que impeçam ou dificultem o atendimento da necessidade que originou a contratação.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
↳ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
↳ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
↳ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
↳ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a gestão de riscos contempla a identificação, análise e avaliação de riscos
- ☐ b) a gestão de riscos contempla o tratamento dos riscos identificados
- ☐ c) a gestão de riscos contempla a definição de responsáveis pelas ações de tratamento dos riscos
- ☐ d) a gestão de riscos é realizada em cada uma das contratações
- ☐ e) a gestão de riscos é realizada em cada uma das contratações de serviços prestados de forma contínua
- ☐ f) as equipes de planejamento das contratações são selecionadas de modo que pelo menos um dos seus integrantes possua capacitação em gestão de riscos
- ☐ g) as equipes de planejamento das contratações são selecionadas de modo que todos os seus integrantes possuam capacitação em gestão de riscos

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Análise de riscos; Avaliação de riscos; Efetividade; Gestão de riscos; Gestão de riscos das contratações; Identificação de riscos; Tratamento de risco.

2320. Contratar e gerir com base em desempenho

2321. A organização adota métricas objetivas para mensuração de resultados do contrato e vinculação da remuneração da contratada ao desempenho apresentado.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização atende ao caput para contratos de prestação de serviços de tecnologia da informação
- ☐ b) a organização atende ao caput para contratos de serviços prestados de forma contínua
- ☐ c) a organização atende ao caput para contratos de outros serviços

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Contratar com base em desempenho; Gerir com base em desempenho; TI (Tecnologia da Informação).

2322. Como condição para as prorrogações contratuais, a organização avalia se a necessidade que motivou a contratação ainda existe e se a solução escolhida ainda é a mais vantajosa para suprir essa necessidade.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização realiza esse tipo de análise para contratos de serviços de tecnologia da informação
- ☐ b) a organização realiza esse tipo de análise para contratos de serviços prestados de forma contínua
- ☐ c) a organização realiza esse tipo de análise para contratos dos demais serviços

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Organização; Contratar com base em desempenho; Gerir com base em desempenho.

2330. Realizar planejamento das contratações

2331. A organização executa processo de planejamento das contratações.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↪ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↪ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) a organização aprova um plano de contratações (ou documento similar) para o período mínimo de um ano
- ☐ b) os setores relevantes da organização participam da elaboração do plano de contratações
- ☐ c) cada item do plano de contratações, incluindo suas atualizações, está associado a um projeto ou a um processo alinhado à estratégia da organização
- ☐ d) o plano de contratações é aprovado pelo dirigente máximo (refere-se ao dirigente da organização que ora responde ao questionário)
- ☐ e) a organização divulga o plano de contratações na Internet.
 - ↪ Informar a localização (URL) do Plano de Contratações:

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Dirigente máximo; Plano de Contratações.

2340. Estabelecer processos de trabalho de contratações

2341. A organização definiu processo de trabalho para planejamento de cada uma das contratações.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↪ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↪ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) o processo contempla procedimentos padronizados para planejamento da contratação
- ☐ b) o processo contempla definição interna de papéis e responsabilidades dos colaboradores que atuam nessa etapa
- ☐ c) o processo contempla modelos padronizados para os documentos a serem elaborados na atividade (p.ex. especificações técnicas padronizadas, minutas de edital)
- ☐ d) o processo contempla a exigência de que as equipes alocadas reúnam as competências necessárias para o desempenho das atividades

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Colaboradores; Competências; Papéis e responsabilidades; Processo de trabalho para planejamento de cada uma das contratações.

2342. A organização definiu processo de trabalho para seleção de fornecedores.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↪ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↪ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) o processo contempla procedimentos padronizados para seleção de fornecedores (p.ex. Listas de verificação para pregoeiro)
- ☐ b) o processo contempla definição interna de papéis e responsabilidades dos colaboradores que atuam nessa etapa
- ☐ c) o processo contempla modelos padronizados para os documentos a serem elaborados na atividade (p. ex. modelo de documento de resposta de recurso de licitante)
- ☐ d) o processo contempla a exigência de que as equipes alocadas reúnam as competências necessárias para o desempenho das atividades

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Colaboradores; Competência; Papéis e responsabilidades; Processo de trabalho para seleção de fornecedores.

2343. A organização definiu processo de trabalho para gestão de contratos.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
 - ↪ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
 - ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
 - ↪ Indique que leis e/ou normas são essas:
 - ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
 - ↪ Identifique esses estudos:
 - ☐ Não se aplica por outras razões.
 - Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) o processo contempla normas de fiscalização e procedimentos padronizados para a gestão de contratos, incluindo a conformidade legal
- ☐ b) em cada indicação de gestor e fiscal, a autoridade competente avalia objetivamente a capacidade do indicado de assumir responsabilidade por mais um contrato (conforme sua complexidade e demanda de atuação), frente aos contratos pelos quais já tem responsabilidade, registrando o resultado dessa avaliação entre as justificativas da indicação

- ☐ c) o processo contempla definição interna de papéis e responsabilidades dos colaboradores que atuam nessa etapa
- ☐ d) o processo contempla modelos padronizados para documentos utilizados na gestão de contratos (p.ex. plano de trabalho, plano de inserção, portaria de designação gestor/fiscais, designação de preposto, ordem de serviço ou de fornecimento, termo de entrega, termo de recebimento provisório, termo de recebimento definitivo, solicitação de reparo em serviço ou fornecimento, termo de rejeição, registro de ocorrências, histórico de gestão do contrato, comunicações à contratada, solicitação de sanção e solicitação de repactuação)
- ☐ e) o processo contempla a exigência de que as equipes alocadas reúnam as competências necessárias para o desempenho das atividades

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Colaboradores; Competência; Papéis e responsabilidades; Processo de trabalho para gestão de contratos.

2344. A organização torna públicos os documentos relacionados com cada contratação, contemplando as fases de planejamento, seleção do fornecedor e gestão contratual, excepcionados os casos de sigilo amparados pela legislação.

- ☐ Não adota
- ☐ Há decisão formal ou plano aprovado para adotá-lo
- ☐ Adota em menor parte
- ☐ Adota parcialmente
- ↳ Indique quais as evidências dessa adoção:
- ☐ Adota em maior parte ou totalmente
- ↳ Indique quais as evidências dessa adoção:
- ☐ Não se aplica
- ☐ Não se aplica porque há lei e/ou norma, externa à organização, que impede a implementação desta prática.
- ↳ Indique que leis e/ou normas são essas:
- ☐ Não se aplica porque há estudos que demonstram que o custo de implementar este controle é maior que o benefício que seria obtido dessa implementação.
- ↳ Identifique esses estudos:
- ☐ Não se aplica por outras razões.
- Explique que razões são essas:

Visando explicitar melhor o grau de adoção do controle, marque abaixo uma ou mais opções que majoritariamente caracterizam sua organização:

- ☐ a) o Estudo Técnico Preliminar (ETP) das contratações é publicado na internet
- ☐ b) o documento de formalização da demanda é publicado na internet
- ☐ c) o Termo de Referência (TR) ou projeto básico das contratações é publicado na internet
- ☐ d) o edital de licitação das contratações (ou instrumento convocatório equivalente) é publicado na internet
- ☐ e) as manifestações das partes interessadas (pedidos de esclarecimento, impugnações e representações) e as respectivas respostas são publicadas na internet
- ☐ f) a ata de julgamento, contendo propostas e lances oferecidos (quando for o caso) é publicada na internet
- ☐ g) o inteiro teor dos contratos, notas de empenho, aditivos e termos de prorrogação de contratos são publicados na internet
- ☐ h) os termos de recebimentos provisórios e definitivos são publicados na internet
- ☐ i) o mapa de gerenciamento de riscos da contratação, incluindo suas eventuais atualizações durante a gestão contratual, é publicado na internet
- ☐ j) a análise realizada e justificativa dada para subsidiar a decisão de prorrogação contratual são publicadas na internet

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Partes interessadas; Processo de Gestão de contratos; Processo de Seleção de fornecedores; Processo de trabalho para planejamento de cada uma das contratações; Risco; Transparência.

2350. Aderência às notas do TCE-RJ

2351. Nas contratações de bens e serviços de Tecnologia da Informação, a organização faz uso da Nota Técnica acerca do Planejamento das Contratações de TI (Nota Técnica TCE-RJ nº 06/2023).

- ☐ Sim

↪ Indique quais as evidências dessa adoção:

☐ Não

↪ Explique as razões dessa adoção:

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: Processo de trabalho para planejamento de cada uma das contratações; Nota Técnica TCE-RJ nº 06/2023.

2360. Contratações de TI da organização

2361. As contratações de TI da organização estão ocorrendo conforme previsto no PEDTIC e no PAC.

☐ Sim

☐ Não

↪ Expresse o motivo:

? Para esclarecimentos nesta questão, consulte, no glossário, os seguintes verbetes: PEDTIC; PAC (Plano de Contratações).

2362. Cite as três principais dificuldades encontradas pela organização na realização de contratações de TI.

- ☐ a) falta de pessoal de TI
- ☐ b) falta de pessoal de TI qualificado
- ☐ c) falta de comprometimento dos gestores
- ☐ d) falta de recursos orçamentários ou financeiros
- ☐ e) falta de capacitação sobre normas de contratação
- ☐ f) complexidade das normas de contratações de TI
- ☐ g) falta de procedimentos internos padronizados
- ☐ h) falta de especificações
- ☐ i) pesquisa de preço ampla
- ☐ j) falta de fornecedores para as soluções de TI
- ☐ k) morosidade no processo de contratação
- ☐ l) outros

↪ Aponte as dificuldades encontradas: